Week 7-10

Lecture (W7) : Cyber Attacks
Lab3 (W8) : Network and Port Scanning Attack
(W9) : Midterm Exam
Lab4 (W10) : Impact of DoS Attack on Network Performance

06016421 IT Infrastructure Security
by P. Sumet, IT/KMITL

Topics

- Review Malware (Ch.6) and DoS Attack (Ch.7) in
  Computer Security: Principles and Practice", 4/e, GE, by William Stallings and Lawrie Brown
- Attack Results
  - Defined as Threat Consequences by RFC 2828 (P. 170)
  - Defined as Threat Modelling
- Anatomy of Cyber Attack Represented by Cyber Kill Chain
  - 1. Reconnaissance … 7. Actions on objectives
- Lab Introduction for Weeks 7-8
  - Lab 3-A - Network Scanning Attack
  - Lab 3-B - Port Scanning Attack
- Lab Introduction for Week 10
  - Lab 4-A - Impact of DoS Attack on UDP Traffic
  - Lab 4-B - Impact of DoS Attack on TCP Traffic

Review for Some Attacks

- Attack caused by Malware (อ่าน Ch.6 Stallings)
  - เน้นแพร่กระจาย
    - ต้องพึ่งพาพาหะเท่านั้น
      - Executable Files, Boot Sector, Script Enabled-Text Files
    - ไม่ต้องพึ่งพาพาหะก็ได้
      - แพร่ผ่าน Attack Surfaces ทาง Software, Human, Network
  - เน้นติด Target แล้วโจมตีตามวัตถุประสงค์
    - System/Data Corruption
    - Information Disclosure/Leakage/Breach…
    - Botnets or Actions on Objectives
- DoS/DDoS Attack (อ่าน Ch.7 Stallings)
  - Resource Exhausion Attack
  - Bug/Vulnerability Attack (i.e., expliot a weakness of target)
- Security Control for Attacks : Prevent, Detect, Identify, Correct, and Recovery

Attack Results

- Threat Consequences defined by RFC 2828 (P. 170)
  - Unauthorized Disclosure, Deception, Disruption, Usurpation
- Threat Modelling : See STRIDE (P.10) and DREAD (P.11) in
  https://www.dropbox.com/scl/fi/nidy86mdaz4i7fmpo3ati/Domain-3-Security-Architecture-and-Engineering.pdf?rlkey=mcs2u6wvq4yhm02siy3yyanwu&dl=0

STRIDE :

- Spoofing
- Tampering
- Repudiation
- Information Disclosure
- Denial of Service
- Elevation of Privilege

DREAD :

- Damage
- Reproducibility
- Exploitability
- Affected Users
- Discoverability

Cyber Kill Chain

- To represent an anatomy of cyber attack
- Developed by Lockheed Martin.
- The Cyber Kill Chain® framework is part of the Intelligence Driven Defense® model for identification and prevention of cyber intrusions activity.
- The model identifies what the adversaries must complete in order to achieve their objective.
- See https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html
- See https://youtu.be/oCUrkc_0tmw?si=JI_cat_E6aFJneVa



Credit: https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html

Reconnaissance

- รูปแบบ
  - Passive - รอเก็บข้อมูลที่เขาคุยกันเฉยๆ
  - Active - แกล้งส่ง Probe หรือ Request แล้วเก็บ Response
- เป้าหมาย
  - Information Gathering/Collection
  - Network/Port Scanning
  - Host/Service Enumuration
  - Network/System Mapping
  - ...

Performing Network Reconnaissance

Network reconnaissance is a crucial part of any hacking operation. Any information that a hacker can learn about the target environment can help in identification of potential attack vectors and targeting exploits to potential vulnerabilities. By using a combination of passive and active reconnaissance tools and techniques, a hacker can maximize the information collected while minimizing their probability of detection.

Top passive recon tools

In passive reconnaissance, the hacker never interacts directly with the target's network. The tools used for passive reconnaissance take advantage of unintentional data leaks from an organization to provide the hacker with insight into the internals of the organization's network.

1. Wireshark
2. Google
3. FindSubDomains.com
4. VirusTotal
5. Shodan

Top active recon tools

Tools for active reconnaissance are designed to interact directly with machines on the target network in order to collect data that may not be available by other means. Active reconnaissance can provide a hacker with much more detailed information about the target but also runs the risk of detection.

1. Nmap
2. Nessus
3. OpenVAS
4. Nikto
5. Metasploit

Credit: https://www.infosecinstitute.com/resources/hacking/top-10-network-recon-tools/

Top passive recon tools

In passive reconnaissance, the hacker never interacts directly with the target's network. The tools used for passive reconnaissance take advantage of unintentional data leaks from an organization to provide the hacker with insight into the internals of the organization's network.

1. Wireshark

Wireshark is best known as a network traffic analysis tool, but it can also be invaluable for passive network reconnaissance. If an attacker can gain access to an organization's Wi-Fi network or otherwise eavesdrop on the network traffic of an employee (e.g., by eavesdropping on traffic in a coffee shop), analyzing it in Wireshark can provide a great deal of useful intelligence about the target network.
By passively eavesdropping on traffic, a hacker may be able to map IP addresses of computers within the organization's network and determine their purposes based on the traffic flowing to and from them. Captured traffic may also include version information of servers, allowing a hacker to identify potentially vulnerable software that can be exploited.

2. Google

Google can provide a vast amount of information on a variety of different topics. One potential application of Google is for performing passive reconnaissance about a target.
The information that an organization posts online can provide a massive amount of information about their network. The organization's website, especially its career page, can provide details of the types of systems used in the network. By using specialized Google queries (Google Dorking), it's also possible to search for files that were not intentionally exposed to the internet but still publicly available as well.

3. FindSubDomains.com

FindSubDomains.com is one example of a variety of different websites designed to help identify websites that belong to an organization. While many of these sites may be deliberately intended for public consumption and others may be protected by login pages, the possibility exists that some are unintentionally exposed to the internet. Accessing error pages or unintentionally exposed pages (that should belong on the company intranet) can provide valuable intelligence about the systems that the company uses.

4. VirusTotal

VirusTotal is a website designed to help with analysis of potentially malicious files. Anyone with an account on the service can upload files or URLs for analysis and receive results that describe whether or not the file or website is likely to be malicious, behavioral analysis and other potential indicators of compromise.
The problem with VirusTotal is that it, and other similar sites, make the same information available to any free subscriber (and provide more data to paid users). As attacks become more sophisticated and targeted, malware or malicious websites targeting an organization may include sensitive internal data. As a result, terabytes of sensitive data are being uploaded to the service by companies trying to determine if they are the victim of an attack. A hacker searching through the data provided on VirusTotal by keywords associated with a company can potentially find a great deal of valuable intelligence.

5. Shodan

Shodan is a search engine for internet-connected devices. As the Internet of Things grows, individuals and organizations increasingly are connecting insecure devices to the internet.
Using Shodan, a hacker may be able to find devices within the IP address range belonging to a company, indicating that they have the device deployed on their network. Since many IoT devices are vulnerable by default, identifying one or more on the network may give a hacker a good starting point for a future attack.

Credit: https://www.infosecinstitute.com/resources/hacking/top-10-network-recon-tools/

Top active recon tools

Tools for active reconnaissance are designed to interact directly with machines on the target network in order to collect data that may not be available by other means. Active reconnaissance can provide a hacker with much more detailed information about the target but also runs the risk of detection.

1. Nmap
Nmap is probably the most well-known tool for active network reconnaissance. Nmap is a network scanner designed to determine details about a system and the programs running on it. This is accomplished through the use of a suite of different scan types that take advantage of the details of how a system or service operates. By launching scans against a system or a range of IP addresses under a target's control, a hacker can learn a significant amount of information about the target network. (See How to use Nmap and other network scanners.)

2. Nessus
Nessus is a commercial vulnerability scanner. Its purpose is to identify vulnerable applications running on a system and provides a variety of details about potentially exploitable vulnerabilities. Nessus is a paid product, but the comprehensive information that it provides can make it a worthwhile investment for a hacker.

3. OpenVAS
OpenVAS is a vulnerability scanner that was developed in response to the commercialization of Nessus. The Nessus vulnerability scanner was previously open-source, and, when it became closed-source, OpenVAS was created off of the last open-source version to continue to provide a free alternative. As a result, it provides a lot of the same functionality as Nessus but may lack some of the features developed since Nessus was commercialized.

4. Nikto
Nikto is a web server vulnerability scanner that can be used for reconnaissance in a manner similar to Nessus and OpenVAS. It can detect a variety of different vulnerabilities but is also not a stealthy scanner. Scanning with Nikto can be effective but is easily detectable by an intrusion detection or prevention system (like most active reconnaissance tools).

5. Metasploit
Metasploit is primarily designed as an exploitation toolkit. It contains a variety of different modules that have prepackaged exploits for a number of vulnerabilities. With Metasploit, even a novice hacker has the potential to break into a wide range of vulnerable machines.

Although it was designed as an exploit toolkit, Metasploit can also be effectively used for reconnaissance. At the minimum, using the autopwn option on Metasploit allows a hacker to try to exploit a target using any means necessary. More targeted analysis can allow a hacker to perform reconnaissance using Metasploit with more subtlety.

Credit: https://www.infosecinstitute.com/resources/hacking/top-10-network-recon-tools/

Lab 3-A : Network Scanning Attack

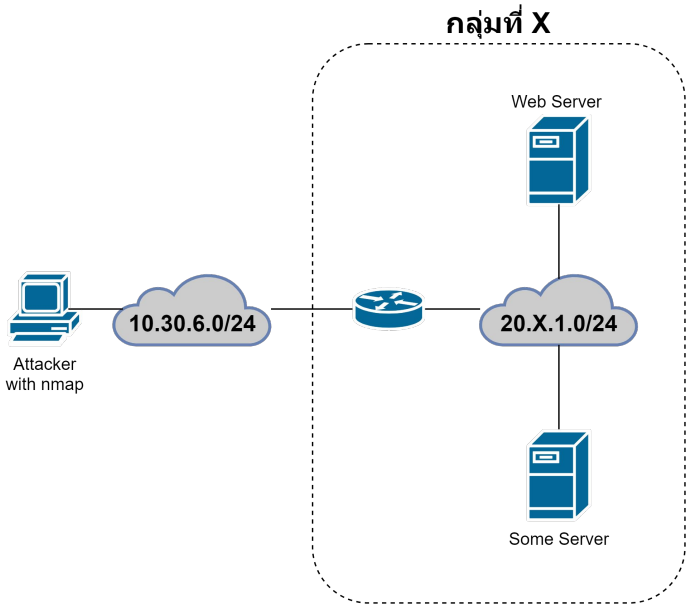
1. สร้าง Network ตาม Topology ที่กำหนด โดยให้

    Web Server มี IP Address: 20.X.1.123 Port: 8080
    Some Server มี IP Address: 20.X.1.77 Port: 2025

2. ใช้ nmap ทำการ scan ว่าพบ Hosts และ Services ตามที่เปิดไว้หรือไม่ โดยลอง nmap ใน mode ต่างๆ

3. ทำรายงานผลการ nmap ว่าได้ข้อมูลอะไรบ้าง

4. วิเคราะห์ผลกระทบที่เกิดขึ้นที่มีต่อ Server และ Network อาจจะใช้ข้อมูลจาก network monitoring tools วัดปริมาณภาระงานที่เกิดขึ้น (ถ้ามี)



Lab 3-B : Port Scanning Attack

1. ให้ Scan ว่า Host ??? Server (IP จะแจ้งในคลาส) เปิด Port/Service จำนวนเท่าไรและอะไรบ้าง

2. ทำรายงานผลที่ได้

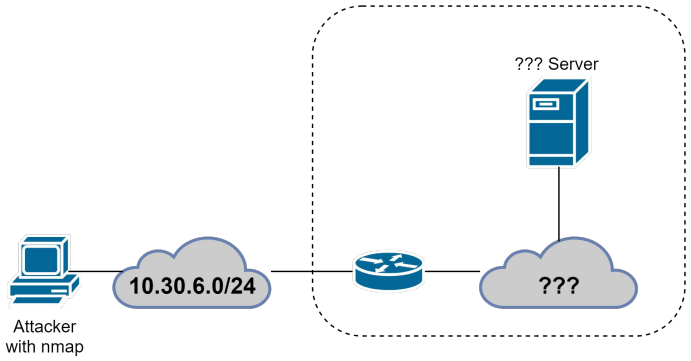
(Option - คะแนนพิเศษ)

3. ใช้ข้อมูลที่ได้หา Password ของ User ชื่อ l???

4. ใช้ข้อมูลที่ได้หา Password ของ User ชื่อ a???

5. หา flag ในรูปแบบ XXXXXXXXX (9 ตัวอักษร)

6. ทำรายงานผลที่ได้ พร้อมกับอภิปรายปัญหาและอุปสรรค



Week 10
Lab 4 (W10) - Impact of DoS Attack on Network Performance

06016421 IT Infrastructure Security
by P. Sumet, IT/KMITL